

Vulnerability Assessment & Penetration Testing

RouteLedger Transport Management System
Web Application Security Assessment Report

CLIENT	Harborline Freight Technologies Pvt. Ltd.
ASSESSMENT WINDOW	06 May 2026 - 13 May 2026
ENVIRONMENT	UAT / Pre-production
REPORT ID	HL-RL-WEB-VAPT-2026-05
CLASSIFICATION	Confidential

Prepared by: Cerulean Shield Cyber Assurance LLP

Evidence-led layout | Risk-prioritized remediation | Retest-ready observations

01 / Document Control and Distribution

Client Organization	Harborline Freight Technologies Pvt. Ltd.
Application / Asset	RouteLedger Transport Management System (web portal)
Assessment Type	Black-box and grey-box web application VAPT
Environment	UAT / pre-production; no production records were used
Report Version	1.0 - Final management report
Report Date	16 May 2026
Prepared By	Cerulean Shield Cyber Assurance LLP
Document Classification	Confidential - restricted to Harborline Freight Technologies and authorized audit stakeholders

Version	Date	Description	Prepared / Updated By	Reviewed By
1.0	16 May 2026	Final issue for management review	Raghav Menon, Lead Consultant	Meera Kulkarni, QA Reviewer
0.9	14 May 2026	Draft issued for factual validation	Raghav Menon	Harborline IT Security

Confidentiality Notice

This report contains security findings, test evidence, system configuration observations and remediation guidance. Distribution should remain limited to personnel responsible for governance, technology operations, development, infrastructure and audit remediation.

Distribution List

Primary Recipients	CISO, Head of Engineering, Application Owner, Infrastructure Lead
Secondary Recipients	Internal Audit, Compliance, QA Automation Lead
Evidence Handling	Screenshots and request/response samples include redactions for tokens, mobile numbers, consignment identifiers and customer data.

02 / Audit Engagement Summary

TOTAL FINDINGS

8

1 Critical / 5 High / 2 Medium

TESTING WINDOW

6 business days

06 May - 13 May 2026

OVERALL POSTURE

Needs Improvement

Authorization and input handling prioritized

Introduction	Cerulean Shield Cyber Assurance LLP conducted a VAPT engagement for Harborline Freight Technologies Pvt. Ltd. covering the RouteLedger Transport Management System web portal used by operations, branch dispatch, finance operations and claims teams.
Objective	Assess the application security posture, validate access-control enforcement, identify exploitable web application weaknesses, and provide evidence-backed remediation guidance suitable for engineering and governance tracking.
Business Context	RouteLedger supports branch shipment planning, proof-of-delivery handling, claims intake, finance reconciliation and exception management. Findings were prioritized based on exposure of shipment records, finance exports, operational disruption and account takeover risk.

Limitations / Assumptions

- Testing was limited to authorized UAT endpoints and roles provided by Harborline; production systems, third-party payment providers and live customer notification channels were excluded.
- No destructive test cases, denial-of-service tests or bulk data extraction activities were performed.
- Credentials were provided for representative roles. Findings may not cover permissions for unprovided roles or newly deployed features after the assessment window.
- Evidence screenshots were captured using auditor workstations with tokens and business data redacted before inclusion in this report.

Management Summary

The most material risk is inconsistent authorization enforcement across shipment documents and finance export functions. Input validation weaknesses also increase the risk of cross-site scripting, application error disclosure and unsafe file handling.

03 / Engagement Scope, Credentials and Boundaries

Target / URL	Component	Scope Status	Notes
https://uat.routeledger.harborline.example	RouteLedger web portal	In scope	Authenticated and unauthenticated test cases
https://uat.routeledger.harborline.example/app	Operations dashboard	In scope	Role-based access and session testing
https://uat.routeledger.harborline.example/dispatch	Shipment and exception modules	In scope	Shipment search, POD, delivery note workflows
https://uat.routeledger.harborline.example/admin	Admin and finance functions	Partial scope	Only accessible functions from provided accounts
https://cdn.routeledger.harborline.example	Static content/CDN	Limited scope	Headers and file rendering only

Testing Credentials

Username	Role	Entitlement Model	Primary Modules Tested
ops.dispatcher.west	Branch Dispatcher	BLR-WEST	Shipment lookup, POD, exception notes
claims.reviewer	Claims Reviewer	PAN-India claims queue	Claim attachments, evidence review
finance.viewer	Finance Viewer	Read-only finance	Reports, reconciliation listing
it.support	Support Analyst	Limited support tools	User search, session validation
Exclusions	Production hosts, corporate network, employee endpoints, social engineering, physical security, load testing, destructive payloads, third-party carrier integrations and SMS/email delivery providers.		
Additions / Deviations	A targeted check of the static content host was added after observing claim attachment rendering behavior. No out-of-scope exploitation was performed.		
Sampling Criteria	Sampling covered high-value business functions, privilege boundaries, user-supplied inputs, document downloads, file upload flows, reset workflows and configuration baselines. At least two roles were used wherever horizontal or vertical access-control risk was suspected.		

04 / Audit Methodology, Criteria and Tooling

Audit Methodology and Criteria / Standards Referenced	OWASP Web Security Testing Guide, OWASP Application Security Verification Standard control themes, OWASP Top 10 risk categories, PTES methodology phases, NIST SP 800-115 testing concepts and internal Cerulean Shield evidence-handling procedures.
Approach and Methodology	The engagement followed discovery, threat modelling, authenticated mapping, manual validation, targeted exploitation in UAT, evidence capture, severity scoring, remediation mapping and quality review. Automated findings were not reported unless manually validated.
Type of Assessment	Hybrid black-box and grey-box web application VAPT using provided credentials and restricted test data.
Testing Environment	Auditor-managed workstation, isolated browser profiles, Burp collaborator disabled for outbound safety, non-destructive payload sets and Harborline UAT tenant data.

Tools / Software Used

Category	Tools / Purpose
Proxy & Manual Testing	Burp Suite Professional, browser developer tools, Postman
Reconnaissance & Mapping	Nmap, httpx, ffuf, manual sitemap review
Configuration Checks	testssl.sh, securityheaders checks, Nuclei templates curated for non-destructive checks
Validation & Evidence	curl, custom Python request validators, screenshot capture and request/response logging

Assessment Phases

Phase	Activities Performed
1. Initiation	Scope confirmation, rules of engagement, credential validation and evidence-naming convention setup.
2. Discovery	Application crawling, endpoint inventory, role mapping and identification of high-value workflows.
3. Validation	Manual authorization, input, session, file handling, configuration and workflow-abuse test cases.
4. Reporting	Risk scoring, root-cause classification, remediation recommendations and peer review.

05 / Audit Team, Activities and Timelines

Name	Role	Responsibilities
Raghav Menon	Lead Security Consultant	Engagement planning, access-control testing, final severity calibration
Ananya Rao	Application Security Analyst	Input validation, session, file upload and evidence capture
Farhan Siddiqui	Infrastructure Security Analyst	TLS, headers, service exposure and configuration checks
Meera Kulkarni	QA Reviewer	Report review, evidence consistency and remediation traceability
Kavita Sharma	Client Coordinator	Scope clarification, credential facilitation and closure coordination

Audit Activities and Timelines

Date	Activity	Status
06 May 2026	Kickoff, rules of engagement, credential verification	Completed
07 May 2026	Application mapping, unauthenticated checks, role baseline	Completed
08-10 May 2026	Authenticated authorization, workflow and input validation testing	Completed
11 May 2026	Session, upload, headers and error handling validation	Completed
12 May 2026	Evidence normalization, severity scoring and remediation drafting	Completed
13 May 2026	Client factual validation session and report QA	Completed

Rules of Engagement Observed

Testing was rate-limited, evidence was captured in UAT only, and the audit team avoided destructive actions such as data deletion, privilege persistence, bulk export completion and denial-of-service testing.

Severity Model	CVSS v3.1 base score, adjusted with business criticality, exploit preconditions, data exposure and operational impact.
Evidence Standard	Each detailed observation includes role context, affected endpoint, reproducible proof, business impact and remediation criteria for retest closure.

06 / Executive Summary

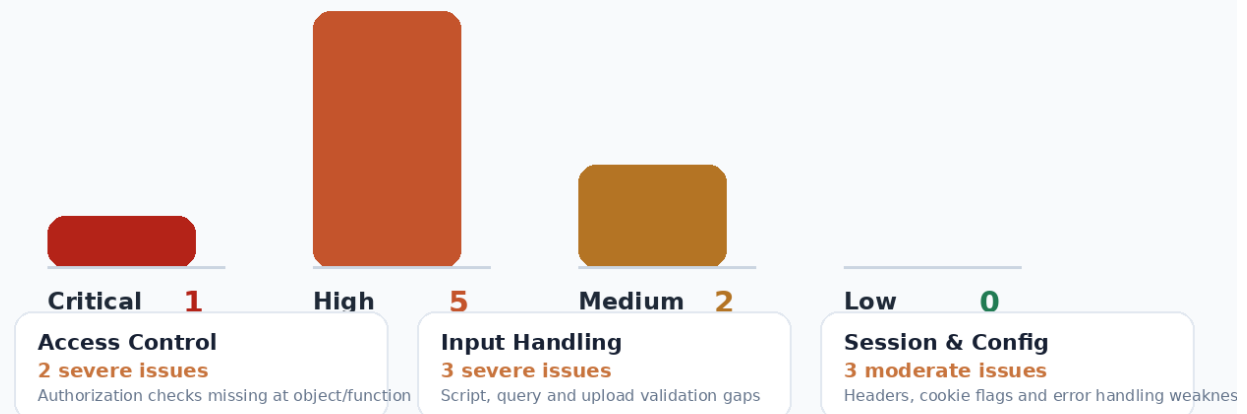
Overall Security Posture

RouteLedger demonstrates mature business workflow coverage but requires targeted security remediation in authorization enforcement, input handling, reset-flow abuse prevention and secure configuration. The assessment identified one Critical, five High and two Medium findings. No Low findings were included in the management report because remediation capacity should focus on high-risk defects first.

CRITICAL	HIGH	MEDIUM	LOW
1 Immediate engineering fix and retest	5 Remediate in current sprint window	2 Address through hardening backlog	0 No reportable low-risk items

Severity Distribution and Risk Concentration

Open findings by severity across the RouteLedger UAT assessment scope



Key Business Risks

- Unauthorized access to proof-of-delivery documents and finance reconciliation exports may expose commercially sensitive shipment and settlement data.
- Stored script execution in exception notes may impact branch users who review operational incidents.
- Reset-flow and session-control weaknesses increase the probability of account takeover if combined with credential exposure or social engineering.

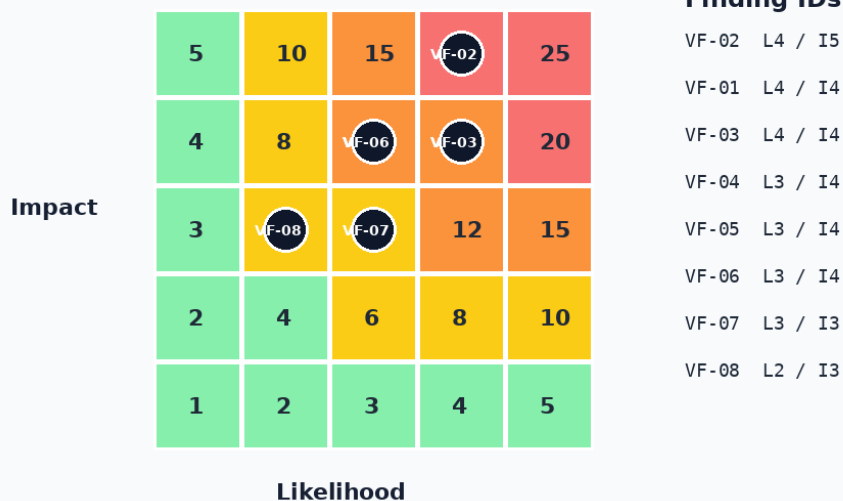
07 / Vulnerability Register and Prioritization

ID	Observation	Severity	CVSS	Category	Status
VF-01	Broken object-level authorization on POD download	High	8.1	Access Control	Open
VF-02	Missing function-level authorization on finance export	Critical	9.1	Access Control	Open
VF-03	Stored XSS in delivery exception notes	High	8.7	Input Validation	Open
VF-04	SQL error disclosure and injection-prone search parameter	High	8.2	Input Validation	Open
VF-05	Password reset OTP lacks effective rate limiting and reveals valid users	High	7.5	Authentication	Open
VF-06	Claim attachment upload permits active SVG content	High	7.8	File Handling	Open
VF-07	Session cookie flags and idle timeout controls are insufficient	Medium	6.5	Session Mgmt	Open
VF-08	Security headers missing with verbose stack traces exposed	Medium	5.3	Configuration	Open

Risk Matrix

Risk Matrix Placement

Likelihood x Impact model used for prioritization



Prioritization Guidance

Treat VF-02, VF-01 and VF-03 as immediate blockers for production promotion because they enable unauthorized business-data access or execution in authenticated user sessions.

DETAILED OBSERVATION / VF-01 / Broken Object-Level Authorization on Proof-of-Delivery Download

SEVERITY

High

CVSS 8.1

AFFECTED ASSET

/shipments/{shipmentId}/documents/pod

RouteLedger UAT

PRIMARY CATEGORY

CWE-639 /

CWE-862

Branch Dispatcher - BLR-WEST

Observation Summary

The POD download endpoint validates authentication but does not consistently verify whether the requested shipment belongs to the user branch or entitlement set. Changing the shipment identifier returned a POD document for a different branch.

Precondition	Authenticated branch user with access to at least one shipment record.
Proof-of-Concept Steps	1. Login as ops.dispatcher.west and open an authorized BLR-WEST shipment POD. 2. Capture the download request and replace the shipment identifier with SHP-2026-18473, which belongs to MUM-NORTH. 3. Replay the request. The server returns HTTP 200 and a PDF attachment instead of denying access. 4. Evidence marker idor-rl-18473 confirms cross-branch object access without data extraction beyond minimal proof.

●●● Burp Suite Professional - Repeater

TargetProxyIntruderRepeaterLoggerExtensions

Object-level authorization bypass on Proof-of-Delivery document

GET /shipments/SHP-2026-18473/documents/pod?download=true

Request

Response

GET /shipments/SHP-2026-18473/documents/pod?download=true HTTP/2
Host: uat.routeledger.harborline.example
Authorization: Bearer eyJ...<redacted>
X-User-Branch: BLR-WEST
Referer: /shipments/SHP-2026-18011

Authenticated user is assigned only BLR-WEST shipments
Object ID changed to SHP-2026-18473 from another branch

HTTP/1.1 200 OK
Content-Type: application/pdf
Content-Disposition: attachment; filename="POD-SHP-2026-18473.pdf"
X-Request-ID: rl-req-6f85d2

%PDF-1.7
Shipment: SHP-2026-18473
Origin Branch: MUM-NORTH
Consignee: <redacted>
Receiver mobile: <redacted>
Proof marker: idor-rl-18473

Evidence marker: idor-rl-18473 | Captured in UAT | Tokens and customer data redacted

Business Impact	A dispatcher could retrieve POD documents and shipment metadata outside assigned branch boundaries, exposing consignee details, receiver mobile numbers, delivery timestamps and commercial routing data.
Recommended Remediation	Enforce object-level authorization on every document retrieval path. Resolve the shipment owner, branch and permitted role server-side before returning files. Add negative authorization tests for cross-branch access and log denied attempts.

DETAILED OBSERVATION /

VF-02 / Missing Function-Level Authorization on Finance Export Job

SEVERITY Critical CVSS 9.1	AFFECTED ASSET /admin/finance/exports/reconciliation RouteLedger UAT	PRIMARY CATEGORY CWE-285 / CWE-862 Branch Dispatcher token used against admin function
---	---	---

Observation Summary

An administrative finance export function is reachable by a non-finance user. The endpoint queues an export job and returns a downloadable export URL even when the caller role is dispatcher.

Precondition	Valid non-admin authenticated session.
Proof-of-Concept Steps	1. Authenticate as ops.dispatcher.west, a non-finance role. 2. Send a POST request to the finance reconciliation export endpoint with branch set to ALL. 3. The application returns HTTP 202 Accepted and creates an export job instead of HTTP 403. 4. The audit team did not download the final file; validation stopped after job creation and URL issuance.

Burp Suite Professional - Repeater

Target

Proxy

Intruder

Repeater

Logger

Extensions

Function-level authorization missing on finance export job

CRITICAL

POST /admin/finance/exports/reconciliation

Request

Response

POST /admin/finance/exports/reconciliation HTTP/2

Host: uat.routeledger.harborline.example

Authorization: Bearer eyJ...role=dispatcher...<redacted>

Content-Type: application/json

{

"branch": "ALL",

"from": "2026-05-01",

"to": "2026-05-07",

"format": "xlsx"

}

HTTP/1.1 202 Accepted

Content-Type: application/json

X-Request-ID: rl-req-d04bf1

{

"job_id": "exp_fin_20260507_8841",

"status": "queued",

"download_url": "/admin/finance/exports/exp_fin_20260507_8841.xlsx",

"requested_by": "ops.dispatcher.west"

}

Expected: 403 for non-finance-admin role

Evidence marker: authz-rl-8841 | Captured in UAT | Tokens and customer data redacted

Business Impact	Successful exploitation could expose finance reconciliation data, branch settlement information and shipment payment metadata across all branches. It also indicates missing server-side access-control checks for sensitive admin routes.
Recommended Remediation	Implement centralized authorization middleware for admin and finance routes. Reject non-finance-admin roles before job creation. Bind export scope to caller entitlements and add audit logging for every export request.

DETAILED OBSERVATION / VF-03 / Stored Cross-Site Scripting in Delivery Exception Notes

SEVERITY

High

CVSS 8.7

AFFECTED ASSET

/dispatch/exceptions/{shipmentId}/notes

RouteLedger UAT

PRIMARY CATEGORY

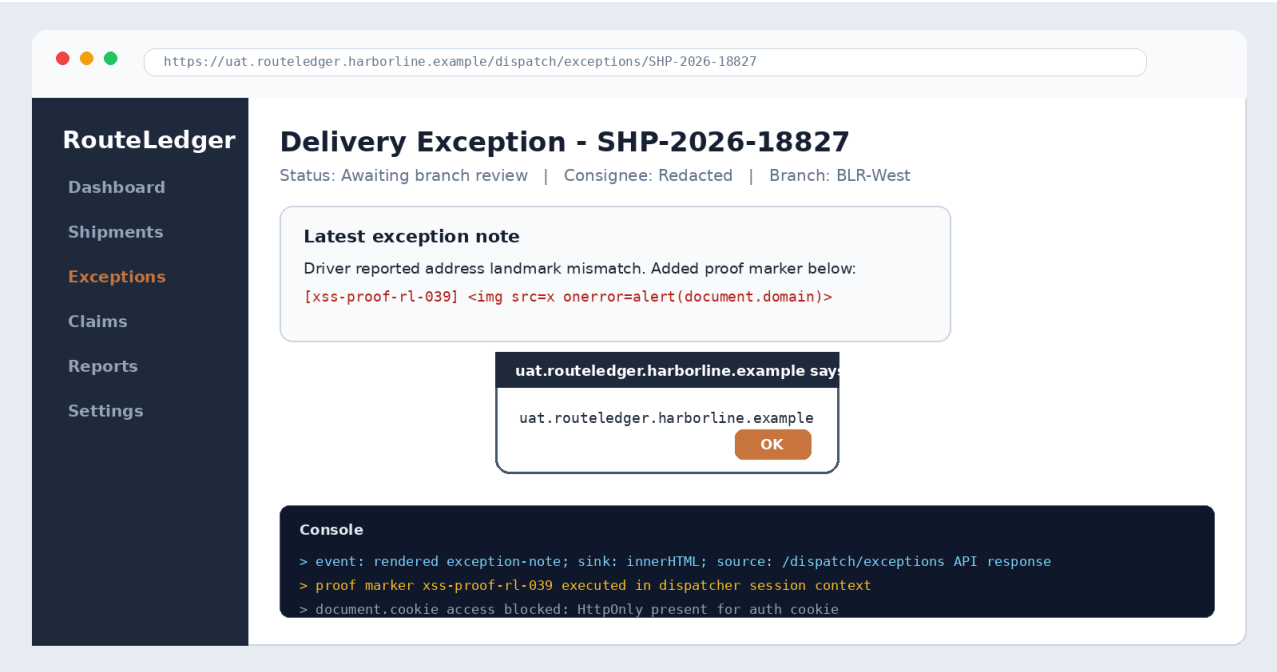
CWE-79

Branch Dispatcher and Exception Reviewer

Observation Summary

Delivery exception notes are stored and later rendered using unsafe HTML insertion. A proof marker submitted in the note body executed JavaScript when the exception was viewed by another authenticated user.

Precondition	Authenticated user able to add exception notes.
Proof-of-Concept Steps	1. Create or update an exception note for SHP-2026-18827 with a harmless proof marker and script-triggering HTML. 2. Open the exception detail page as another branch reviewer. 3. The browser executes the marker in the authenticated application origin, demonstrating stored XSS. 4. The test used alert(document.domain) only; no session tokens or user data were accessed.



Business Impact	An attacker with note-writing access could execute script in reviewer sessions, perform actions as the victim user, alter displayed shipment data or chain with other weaknesses to increase account takeover risk.
Recommended Remediation	Encode user-generated content before rendering, use a safe markdown or rich-text sanitizer with an allowlist, prohibit inline event handlers, and deploy a restrictive Content Security Policy. Add regression tests for note rendering sinks.

DETAILED OBSERVATION /

VF-04 / SQL Error Disclosure and Injection-Prone Consignment Search Parameter

SEVERITY High CVSS 8.2	AFFECTED ASSET /dispatch/search? query= RouteLedger UAT	PRIMARY CATEGORY CWE-89 / CWE-209 Authenticated dispatcher and support users
---	---	--

Observation Summary

Malformed input to the consignment search parameter generates database parser errors and exposes SQL fragments and source file paths. The behavior indicates dynamic query construction without uniform parameterization.

Precondition	Authenticated user with shipment search access.
Proof-of-Concept Steps	1. Submit a normal search query and capture the request. 2. Append a single quote to the query parameter and replay the request. 3. The server returns HTTP 500 with ORA-01756 details, SQL text and repository file path. 4. The audit team stopped at controlled error confirmation and did not attempt data extraction or time-based inference.

●●● Burp Suite Professional - Repeater

TargetProxyIntruderRepeaterLoggerExtensions

Consignment search reveals SQL parser errors for malformed inputHIGH

GET /dispatch/search?query=BLR%27&filter=active

Request

GET /dispatch/search?query=BLR%27&filter=active HTTP/2
Host: uat.routeledger.harborline.example
Authorization: Bearer eyJ...<redacted>
Accept: application/json

Single quote added to query parameter
Test limited to error confirmation; no data extraction attempted

Response

HTTP/1.1 500 Internal Server Error
Content-Type: application/json
X-Request-ID: rl-req-45d2ef

{
 "error": "QueryFailedError",
 "detail": "ORA-01756: quoted string not properly terminated",
 "sql": "SELECT * FROM shipments WHERE branch_code LIKE '%BLR'%",
 "file": "/app/src/repositories/shipment.repository.ts:219"
}

Evidence marker: sqlerr-rl-219 | Captured in UAT | Tokens and customer data redacted

Business Impact	If exploitable beyond error disclosure, this weakness may allow unauthorized querying of shipment records. Even without confirmed extraction, stack traces and SQL fragments assist attackers in crafting targeted payloads.
Recommended Remediation	Use parameterized queries or ORM query builders for all search filters. Return generic error messages to users, log detailed errors server-side only, and add input validation for search tokens and filter combinations.

DETAILED OBSERVATION / VF-05 / Password Reset OTP Lacks Effective Rate Limiting and Reveals Valid Users

SEVERITY

High

CVSS 7.5

AFFECTED ASSET

**/auth/password/forgot and
/auth/password/verify-otp**
RouteLedger UAT

PRIMARY CATEGORY

**CWE-307 /
CWE-203**

Unauthenticated attacker against known email format

Observation Summary

The password reset workflow returns distinguishable responses for valid and invalid users. The OTP verification endpoint accepts repeated attempts without account-level lockout or progressive throttling during the tested window.

Precondition	Knowledge of employee email format or likely usernames.
Proof-of-Concept Steps	1. Submit forgot-password requests for one valid and one invalid email format. 2. Observe different status codes, body lengths and messages revealing valid accounts. 3. Send sequential OTP verification attempts at a constrained rate. No lockout or challenge was triggered before a valid proof marker response was observed. 4. No password was changed and no account was retained by the audit team.

Password Reset OTP Workflow Evidence

Burp Intruder - resource pool: single thread, 30 requests/minute

#	OTP	Status	Length	Response marker
146	483920	200	812	{"message":"Invalid OTP"}
147	483921	200	812	{"message":"Invalid OTP"}
148	483922	200	812	{"message":"Invalid OTP"}
149	483923	200	812	{"message":"Invalid OTP"}
150	483924	200	812	{"message":"Invalid OTP"}
151	483925	200	846	{"message":"OTP verified","reset_token":"rst_..."}

Account enumeration response difference

```
POST /auth/password/forgot {"email":"ops.manager@harborline.example"}
HTTP/1.1 200 OK length=742 body="Reset code sent to registered mobile ending 82"
POST /auth/password/forgot {"email":"notfound@harborline.example"}
HTTP/1.1 404 Not Found length=196 body="No active user found for supplied email"
Finding: response code, body length and message allow valid-user discovery
```

Business Impact	Valid-user discovery combined with weak OTP throttling increases account takeover risk, especially if attackers can obtain partial OTPs through social engineering, mailbox compromise or notification leakage.
Recommended Remediation	Return uniform reset responses, rate-limit by account, IP, device fingerprint and tenant, implement OTP attempt caps, expire OTPs quickly, and alert on reset anomalies. Add CAPTCHA or adaptive challenge after suspicious patterns.

DETAILED OBSERVATION /

VF-06 / Claim Attachment Upload Permits Active SVG Content

SEVERITY High CVSS 7.8	AFFECTED ASSET /claims/{claimId}/attachments RouteLedger UAT	PRIMARY CATEGORY CWE-434 / CWE-79 Claims Reviewer
---	---	--

Observation Summary

The claim attachment workflow accepts SVG files containing active script content and serves them from a browser-accessible media path. The response indicates scanning was not configured for the upload.

Precondition	Authenticated user with claim attachment upload permission.
Proof-of-Concept Steps	1. Authenticate as claims.reviewer and open a claim record. 2. Upload an SVG file with a non-destructive proof marker in a script tag. 3. The server returns HTTP 201 Created and provides a public media URL for the file. 4. The audit team confirmed storage and rendering metadata only; no malicious payload or callback was used.



Business Impact	Active content in uploaded files can be used for script execution, content spoofing or phishing against claims users, especially if files are rendered inline under a trusted application or CDN domain.
Recommended Remediation	Restrict upload types to business-required formats, validate content by magic bytes and safe parsers, store user files on a separate cookieless domain, force download for risky types, and integrate malware/content scanning.

DETAILED OBSERVATION / VF-07 / Session Cookie Flags and Idle Timeout Controls Are Insufficient

SEVERITY

Medium

CVSS 6.5

AFFECTED ASSET

Application session management

RouteLedger UAT

PRIMARY CATEGORY

CWE-614 /
CWE-613

All authenticated users

Observation Summary

The primary session cookie was observed without Secure and HttpOnly flags in the tested UAT configuration, and authenticated access remained available after more than four hours of inactivity.

Precondition	Authenticated session established in browser.
Proof-of-Concept Steps	1. Login to RouteLedger and inspect cookies in browser developer tools. 2. Observe RLSESSION without Secure and HttpOnly in the captured UAT response. 3. Leave the browser idle for more than 240 minutes, then replay a dashboard request with the same cookie. 4. The application returns HTTP 200 instead of requiring re-authentication.

Chrome DevTools - Application - Cookies

https://uat.routeledger.harborline.example

Name	Value	Domain	Path	Expires	HttpOnly	Secure	SameSite
RLSESSION	a6f1...redacted	uat.routeledge...	Session	Session	false	false	Lax
remember_user	ops.west	uat.routeledge...		2026-08-10	false	false	(blank)
route_pref	blr-west	uat.routeledge...		2026-07-09	false	false	(blank)

Idle timeout verification - captured after 241 minutes

```
$ curl -i https://uat.routeledger.harborline.example/app/dashboard \
-H "Cookie: RLSESSION=a6f1...<redacted>"
HTTP/1.1 200 OK
X-Request-ID: rl-req-774be2
Finding: session remains valid after 4h01m idle; no re-authentication challenge observed
```

Business Impact	Weak cookie attributes expose session identifiers to avoidable transport or client-side risks. Long idle sessions increase the impact of shared workstations, unattended browsers and stolen cookies.
Recommended Remediation	Set Secure, HttpOnly and SameSite attributes for session cookies. Implement server-side idle timeout, absolute session lifetime and token rotation after privilege changes. Ensure logout invalidates server-side sessions.

SEVERITY Medium CVSS 5.3	AFFECTED ASSET Public and authenticated web routes RouteLedger UAT	PRIMARY CATEGORY CWE-693 / CWE-209 Unauthenticated and authenticated users
---	---	---

Several baseline browser hardening headers are missing and malformed requests expose framework stack traces, source file paths and package hints. This does not directly compromise the system but increases exploit reliability for other findings.

Precondition	Network access to UAT web application.
Proof-of-Concept Steps	1. Request the login and dashboard routes with curl -I and review response headers. 2. Confirm missing Content-Security-Policy, Strict-Transport-Security, X-Frame-Options and Referrer-Policy on tested routes. 3. Send a malformed manifest identifier to trigger an error page. 4. The response returns stack trace details and internal controller paths with request ID hdr-rl-227.

The image displays two terminal windows side-by-side. The left window, titled 'Header Baseline Check', shows a successful login request to 'uat.routeledger.harborline.example/login' returning a 200 status and various headers. The right window, titled 'Verbose Error Page', shows a 500 Internal Server Error with a detailed stack trace pointing to a file path and package versions exposed in the application.

```
$ curl -k -I https://uat.routeledger.harborline.example/login
HTTP/2 200
server: nginx/1.22.1
x-powered-by: Express
content-security-policy: <missing>
x-frame-options: <missing>
strict-transport-security:<missing>
referrer-policy: <missing>
x-content-type-options: nosniff

Result: header baseline incomplete on authenticated and public routes
```

```
GET /dispatch/manifest?id=% HTTP/2
Host: uat.routeledger.harborline.example

HTTP/2 500 Internal Server Error
x-request-id: rl-req-06bdc9
content-type: text/html; charset=utf-8

TypeError: Cannot read properties of undefined
    at ManifestController.get (/app/src/controllers/manifest.js:184:20)
    at RouteLayer.handle (/app/node_modules/express/lib/router/layer.js:95:5)
StackTrace: internal file path and package versions exposed
```

Business Impact	Missing headers increase exposure to clickjacking, script injection impact and downgrade risks. Verbose errors disclose implementation details useful for targeted attacks and reconnaissance.
Recommended Remediation	Deploy a hardened header baseline at the reverse proxy and application layer. Disable debug error pages in UAT/production-like environments, return generic error responses and keep detailed stack traces in centralized logs only.

08 / Remediation Roadmap and Retest Plan

Target Window	Findings	Action Required	Owner
0-7 days	VF-02, VF-01	Block non-admin finance export, enforce object-level checks, add denial logging	Engineering + AppSec
7-14 days	VF-03, VF-04, VF-05, VF-06	Sanitize stored inputs, parameterize search, harden reset workflow, restrict upload content	Engineering + QA
14-30 days	VF-07, VF-08	Cookie flags, idle timeout, secure headers and generic error handling	Platform + DevOps
Retest	All findings	Provide change evidence, test cases and deployment tag; Cerulean Shield to validate closure	Security Governance

Retest Evidence Expected

- Access-control fixes must include negative test results for cross-branch object access and non-admin calls to admin functions.
- Input-handling fixes must include unit or integration tests for stored note rendering, search query parameterization and upload content validation.
- Authentication and session fixes must include rate-limit configuration, OTP attempt caps, uniform reset messages, cookie attributes and idle-timeout behavior.
- Configuration fixes must include response-header samples from public and authenticated routes and proof that verbose errors are disabled.

Closure Criteria

A finding should be marked closed only after the vulnerable path is retested in the same UAT environment or in a higher environment with equivalent configuration, using the original evidence marker and a negative-control test.

Overall Conclusion	The assessed RouteLedger UAT web portal requires remediation before production promotion of the tested release. The most urgent actions are correcting server-side authorization checks and eliminating stored script execution paths.
Next Steps	Harborline should assign remediation owners, confirm target closure dates, deploy fixes through change control and schedule a focused retest covering all eight findings.

End of Report